Community Bank Security Plan

Group 5

Praveen Masupatri (120423796)

Ayaan Ahmed (120220383)

Philip Wu (117883442)

TABLE OF CONTENTS

Executive Summary	**3**
Company and Scenario overview	**3**
Root cause analysis	**4**
Critical assets	**5**
Threat Landscape	**6**
Existing Capabilities and gaps.	**7**
Security objectives and prioritization	**8**
Proposed Security Architecture	**9**
Metrics for measuring improvement	**11**
Operational impacts and tradeoffs	**11**
Cost overview and budget flexibility	**12**
Regulatory compliance mapping	**15**
Conclusion	**15**

Executive Summary

In early 2025, our community bank experienced a prolonged and undetected cyberattack that exposed serious gaps in our security infrastructure. The attackers gained access via a phishing email and moved laterally across our flat network, affecting ATM systems, teller workstations, Linux servers, and cloud-hosted services. The breach was only discovered during a third-party audit, triggering mandatory GLBA disclosure.

This incident served as a critical inflection point. It revealed how our outdated architecture and insufficient security measures could not keep pace with modern threats. As a result, we are initiating a phased, comprehensive security overhaul to rebuild a resilient, segmented, and monitored environment. This plan directly addresses each gap exploited during the breach.

With a budget of $400,000, the plan includes deploying EDR and SIEM, enforcing MFA and RBAC, securing remote access, strengthening backup processes, and conducting staff training. These initiatives are aligned with regulatory frameworks such as GLBA, FFIEC, and PCI DSS. Success will be measured through faster threat detection, reduced recovery times, improved compliance readiness, and increased user awareness.

This initiative reflects not only our technical response, but also our commitment to protecting customer trust and ensuring operational continuity in a digital-first era. The implementation of these improvements also lays a foundation for future scalability, supporting the bank's broader strategic growth goals. Through this investment, we aim to build a proactive, resilient cybersecurity culture that enables sustained customer confidence.

Company and Scenario overview

This small-sized community bank operates out of a single central headquarters and employs approximately 200 staff across roles in customer service, finance, administration, and IT.The bank uses Windows workstations for everyday tasks, it runs financial transactions on Linux servers and its ATMs are linked into the internal LAN.

All customer information and core banking data remain on local servers while external services are delivered from Amazon Web Services. All remote access was provided through personally

owned laptops connected to the corporate network via VPNs. No standards were in place for device posture, MFA or encryption at the time of the incident.

A highly skilled attack in January 2025 targeted the bank's systems and exposed a number of vulnerabilities. Employees fell for phishing attempts, allowing the perpetrators to retrieve their login details and navigate the network unimpeded because all systems were connected to each other with no separation between critical and less sensitive data.The intrusion affected key infrastructure but remained undetected until a third-party audit revealed suspicious activity. The attack required notification under GLBA and prompted immediate response and containment measures.

The incident not only exposed technical flaws but also signaled a need for a cultural shift in how security risks are identified and addressed. As threats become more targeted and persistent, the bank's leadership recognized the urgency of implementing lasting structural improvements.

Root cause analysis

Systemic vulnerabilities were discovered following the breach, in both the organization's technical controls and its operational procedures. Network segmentation was completely absent, enabling lateral movement throughout the organization. Network separation was nonexistent between the ATMs, teller terminals and internal computer networks.

The organization had no EDR or SIEM solution in place, leading to complete blindness regarding any suspicious behaviour. Therefore, attackers were able to carry out malicious activities without being detected.

A major vulnerability was introduced by the fact that employees were working remotely. Laptops used by personnel weren't encrypted or managed by Mobile Device Management (MDM) and Multi-Factor Authentication (MFA) wasn't required to access corporate networks with those devices. The unsecured endpoints were easily exploited by attackers.

Additionally, the company's backup systems were neither tested frequently nor encrypted, significantly increasing vulnerabilities in the event of a ransomware attack. Inadequate

employee training and IR planning left staff unable to quickly recognize abnormal behavior and raised concerns.

Critical assets

The following assets are foundational to the bank's ability to operate securely, maintain compliance, and retain customer trust:

Asset	Data/Function	Criticality
Customer Database	PII,account info, loan documents	**Very High**
Teller/Admin Workstations	Access to internal applications and transaction tools	**High**
ATM Systems	Encrypted PINs, card numbers, withdrawal logs	**High(PCI Scope)**
Core Linux Servers	Financial processing and backend services	**Very High**
Web/Mobile Banking	Customer Access portal and cloud interface	**High**
Remote Laptops	Cached credentials, sensitive documents and VPN credentials	**Medium-High**
Backup Systems	Replicated data and system images for recovery	**Very High**
Log and Audit Files	Authentication and system access histories	**Medium**
Network Devices	VLAN Configurations, firewall rules, and routing logic	**Medium**

Protecting these assets is essential to prevent business disruption, safeguard customer privacy, and meet **GLBA**, **FFIEC**, and **PCI DS**S requirements

Threat Landscape

These attackers appear to be nation-state APTs due to the higher intricacies of the attack (months long and undetected, took over many systems like ATMs and remote devices). Nation-state APTs tend to use more time, resources, and have more capabilities than other threats so we have to consider improving our systems to have the highest possible security. We then identified the techniques they had used and ranked it with the DREAD methodology.

In terms of the techniques they used in the environment, we found:

- They start the attack with **Phishing/Credential theft** attacks to create an entry vector. DREAD Score: 35 - Reproducibility, exploitability, and discoverability were high (8+) as the attacker impersonated workers with minimal effort and small damage.

- **Lateral movement** was used to move around the network and access more devices. DREAD Score: 25 - High damage and many users affected (data leaked from database), however, not easily reproducible nor exploitable and quickly discoverable.

- On the website, they used **Web Application Exploits** to gain more control. DREAD Score: 35 - DDoS and web attacks caused lots of damage (downtime) to many users on the site and was easily reproduced, but hard to exploit and quickly discovered.

- Pivoted and established persistence with **Remote Work Device breaches**. DREAD Score: 30 - Affected many workers (users) and reproduced many cases in the environment, but network monitoring discovered the issue and stopped damages.

- While this wasn't used, the attackers were seen to have **ransomware** capabilities. DREAD Score: 40 - Would have low reproducibility and exploitability, but the damage, affected users, and discoverability after this attack would be immense (10 pts each).

- Lastly, another threat which wasn't seen but considered was **Insider Threats**. DREAD Score: 30 - This attacker could stay hidden (barely discoverable), damage a lot, and affect many users but has to be cautious exploiting as they aren't easily replaceable.

Existing Capabilities and gaps.

As we have seen in the scenario that we encountered and the root cause analysis, there are many parts of the bank that still need coverage.

First mentioning some of the current capabilities: there are systems like Windows and Linux servers to process financial data and run software for the bank like the customer database and mobile webpage, as well as simple services like ATM processing and teller PCs. There are also basic IT networking and software tools, so there are also subnets and application monitoring, which lowered damage from attacks like remote device breaches. There are basic firewalls in place, but they cannot detect web attacks and more sophisticated requests.

There are also many security gaps to discuss. We found that there was a phishing email that was both clicked and undetected, so the attack wasn't detected earlier, in either the email system or when the attackers entered the system from that account.

The bank also had a flat network with no segmentation, so there was lots of pivoting between systems (allowed ATM and teller PCs to be attacked), with increased damage through the system. There were also weaknesses in our own remote devices, as the VPN that remote laptops connected through weren't secured and lacked encryption, leading them to be breached in the case of an attack. Lastly, there was no SIEM to monitor these activities, so these attacks worked to the point that we had been compromised for a couple of months and didn't even know it. A last point that was mentioned and is critical is not having any backup capabilities, so any case of corrupted/lost data or ransomware could set back the bank by a lot.

Security objectives and prioritization

Based on the root causes of the incident, the threat landscape, and our security architecture, we have a couple of security objectives for the bank to start on:

1. Securing the network of devices in the bank (High Priority)
2. Hardening devices and data in the organization (High Priority)
3. Adding more monitoring through the webpage and internal network (High Priority)
4. Creating an app and device management system (Medium priority)
5. Creating a training and compliance culture (Medium Priority)

To explain some goals: (1) is a goal to stop lateral movement attacks in the network, so we want to add private networks (like a Web DMZ) to reinforce stability. The goal of (2) is to stop DDoS and ransomware attacks, by making database backups with encryption to allow business continuity and prevent data leakage from those attacks. (3) monitors systems for suspicious activity, such as phishing emails, web attacks, and work device breaches, so response time is minimized. The purpose of (4) is tackling remote device breaches and web app attacks with an automated app patching tool for employees' systems and software, and (5) is for employees to stop clicking phishing links and to teach employees how to identify insider threats.
The first 3 are high priority as it secures the most critical assets (the Core Linux server, Customer database, the Backup Systems are the very highly critical, which all need the network secured, devices/systems hardened, and should be monitored for suspicious activity). The last 2 are lower on priority as they do not focus on the very highly critical assets.

Proposed Security Architecture

We then come up with a list of security changes based on the goals mentioned above including the related point in parentheses:

1. Network Segmentation (1): We plan to make VLANs for certain groups like Admins, Tellers, ATMs, and Remote devices and add firewalls with whitelisting, blocking lateral movement and reducing the probability of network attacks succeeding.

2. DMZ for Public Apps (1): The website & mobile banking apps will filter traffic from the public website and internal networks, and can redirect malicious commands and prevent accessing customer data in the case that these services are compromised.

3. Encrypted Backups & Database Security (2): On a scheduled basis, we plan to automate encrypting the database to be encrypted then later backed up, stopping data leakage and enabling business continuity in the case of data corruption issues.
4. SIEM & Logging (3): We will use a SIEM service and for the current infrastructure, and will need someone to review the logs in the future so will hire a system analyst for this.

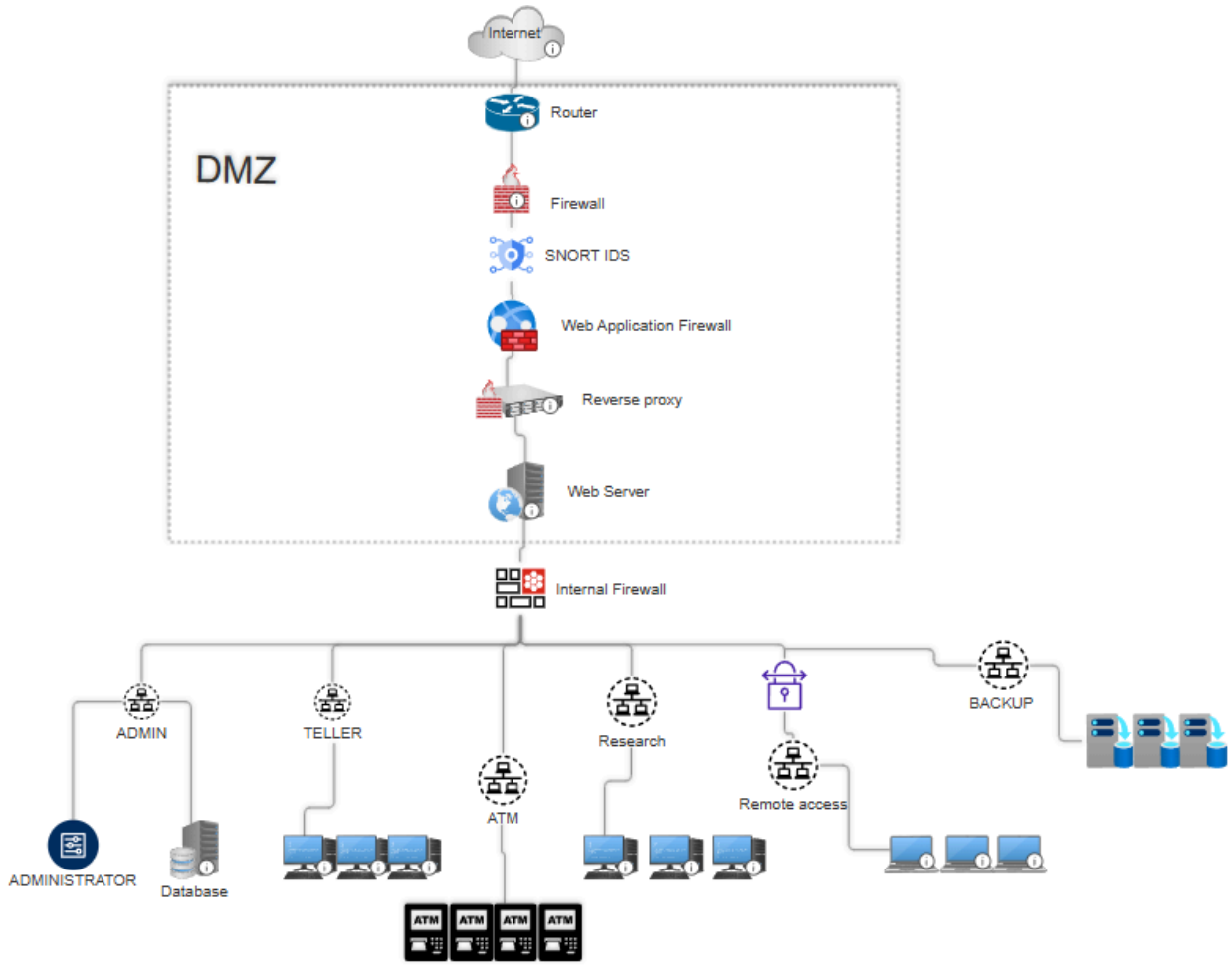
5. EDR (2/3): To further harden devices and allow more monitoring for devices, we will use an Endpoint Detection Response system to identify devices that have issues, and also take actions (reconfigure, restart, or disconnect) on these devices to control them more.

6. MFA & RBAC (2): To further harden applications and data, we will also have MFA and Access control policies, so employees cannot access more than they should be able to.

7. App Control (4): Centralizing a spot for applications, tools, and automating patches well, and stopping disallowed apps can protect devices from weak software and malware.

8. Security Training & Culture (5): We will roll out phishing simulations, train users for privacy & password practices, and conduct incident response drills to ensure our employees know about cybersecurity and are taking action to stop breaches.

To get the talent to roll out these changes, we will hire a system administrator to make these changes over a year, and work on monitoring the Logging tools (SIEM & EDR) afterwards.



Proposed Security Architecture

Metrics for measuring improvement

To evaluate the effectiveness of the proposed security enhancements, the bank will track several key performance indicators. Phishing simulation click rates will be monitored quarterly, with a target reduction below 5% as employee awareness improves. Technical response capabilities will be measured by reductions in Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR), which are expected to drop significantly due to SIEM integration and automated alerting. Endpoint security coverage will also be monitored, aiming for over 95% enrollment in both EDR and MDM systems. Backup recovery capabilities will be tested quarterly to ensure that critical systems can be restored within two hours using encrypted, versioned cloud backups. Finally, patch compliance will be tracked, with the goal of eliminating critical unpatched systems within seven days of release. These metrics will collectively provide a measurable framework for assessing improvements in the bank's security posture and operational resilience.

Operational impacts and tradeoffs

The implementation of this security plan will bring significant improvements to the bank’s overall posture, but it also introduces operational impacts that must be managed. On the positive side, the integration of EDR tools, centralized SIEM, and access control mechanisms will enhance visibility, accelerate incident detection, and reduce exposure to malware and insider threats. Security awareness training and phishing simulations will help create a more cautious workforce, reducing the likelihood of successful social engineering attacks. Centralized patching and device management through MDM platforms will improve IT consistency and reduce vulnerability windows, especially for remote employees.

Nonetheless, these improvements may come with temporary or minor drawbacks. VPN posture validation and MFA can introduce slight delays in user logins or disrupt workflows for users unfamiliar with security prompts. Application control mechanisms such as AppLocker or WDAC might restrict users from executing unsigned scripts or custom tools, particularly among IT staff

or developers. Additionally, initial device enrollment and training enforcement may increase helpdesk load and require more direct involvement from the security administrator.

These impacts, however, are largely transitional. As users adapt and systems become fully integrated, the day-to-day friction will decrease. Overall, the operational tradeoffs are outweighed by the long-term benefits in threat reduction, compliance readiness, and recovery capabilities. The architecture has been designed to strike a balance between usability and security, ensuring that protections are sustainable without overwhelming staff or business processes.

Cost overview and budget flexibility

To maximize security outcomes within a $400,000 budget, each technology in the proposed architecture was selected based on functionality, regulatory alignment, and cost-efficiency. Cisco Catalyst switches and Fortinet FortiGate 60F firewalls, allocated $50,000, provide VLAN segmentation and firewall rules to isolate ATM systems, administrative networks, and remote access. Microsoft Defender for Endpoint P2, combined with native AppLocker controls and Wazuh agents, delivers robust endpoint protection and application control across 200 devices for $80,000. Log aggregation and analysis are handled by the open-source ELK Stack (Elasticsearch, Logstash, Kibana), integrated with Wazuh Manager, offering real-time alerting and behavior-based detection—deployed and managed within a $70,000 budget.

Azure Active Directory P1 and Microsoft Entra MFA, at $25,000, centralize identity management and enforce multi-factor authentication, while role-based access control (RBAC) ensures the principle of least privilege. For remote work, Fortinet VPN, Microsoft Intune (for Windows), and FleetDM (for Mac/Linux) form a layered endpoint compliance and encryption stack for $40,000. Public-facing services are hosted in a DMZ with NGINX reverse proxy, ModSecurity WAF, Snort IDS, and Let’s Encrypt TLS, balancing performance and security at a cost of $45,000. Backup and recovery solutions include Wasabi cloud storage (AES-256 encrypted), Veeam orchestration, and endpoint encryption using BitLocker and FileVault for $30,000. Lastly, $30,000 is dedicated to KnowBe4 phishing simulations, awareness modules, and biannual tabletop incident response drills to build a resilient security culture.

To account for uncertainty, a $30,000 contingency is reserved. If the budget increases by $100,000, the bank could onboard a 24/7 Managed Security Operations Center (SOC) such as Arctic Wolf to monitor alerts, reduce internal burden, and shorten incident response times. Conversely, if the budget is reduced by $100,000, the plan could pivot by replacing FleetDM with a basic open-source MDM, reducing SIEM infrastructure to periodic log analysis, and relying on native OS tools to maintain baseline functionality. This flexible design ensures robust coverage under varied financial conditions.

Category	Product / Tool	Baseline Cost	+ $100K (Add)	– $100K (Reduce)
Network Segmentation	Cisco Catalyst switches + Fortinet FortiGate 60F firewalls	$50,000	–	Keep but reduce port scaling if needed
Endpoint Protection & Control	Microsoft Defender for Endpoint P2 + AppLocker + Wazuh	$80,000	–	Limit Defender licensing to high-risk users only
SIEM & Logging Infrastructure	ELK Stack + Wazuh Manager (self-hosted)	$70,000	Upgrade to hybrid Splunk Cloud deployment	Shift to batch log review (no real-time alerting)
Identity & Access Management	Azure AD P1 + Microsoft Entra MFA	$25,000	–	Retain minimum Azure AD/MFA licensing tier
Secure Remote	Fortinet VPN +	$40,000	–	Replace FleetDM with

Access & MDM	Intune (Windows) + FleetDM (Mac/Linux)			open-source MDM (e.g., Munki/OSQuery)
Web DMZ + WAF + IDS	NGINX Reverse Proxy + ModSecurity WAF + Snort + Let's Encrypt	$45,000	–	Retain but shift to open-source-only config management
Backup & Data Encryption	Wasabi (cloud storage) + Veeam + BitLocker/FileVault	$30,000	–	Scale back backup retention window (less historical data)
Security Awareness & IR	KnowBe4 + Tabletop IR drills	$30,000	Expand to bi-monthly training	Simplify to annual phishing testing only
Optional Add-On	–	–	Add 24/7 Managed SOC (e.g., Arctic Wolf, Blumira)	–
Contingency Buffer	Reserved for scaling/licensing adjustments	$30,000	Partial use for SOC onboarding	Retain for essential updates

Regulatory compliance mapping

The proposed security architecture is purpose-built to meet the regulatory requirements that govern financial institutions, with a strong focus on the **Gramm-Leach-Bliley Act (GLBA), the FFIEC Cybersecurity Framework**, and **PCI DSS**. Under GLBA, the **Safeguards Rule** is addressed through layered technical controls including encryption, access restrictions, and centralized monitoring via a SIEM. Endpoint Detection and Response (EDR), network segmentation, and application controls provide further defense, ensuring that customer data is protected against unauthorized access or modification. The **Privacy Rule** is supported by role-based access control (RBAC), multi-factor authentication (MFA), and audit logging to ensure that only authorized personnel can access sensitive customer information.

The architecture also aligns with the **FFIEC Cybersecurity Framework**, covering all five core domains: Identify, Protect, Detect, Respond, and Recover. Asset classification, threat detection via SIEM and Wazuh, incident escalation procedures,and backup restoration policies all contribute to a robust compliance posture. In addition, **PCI DSS** requirements for cardholder data are met by isolating ATM systems in a dedicated VLAN, applying AES-256 encryption to PINs and transaction logs, and implementing anti-malware solutions and logging mechanisms on all endpoints in PCI scope.

Together, these controls not only meet the required standards but also demonstrate the bank's commitment to proactive, auditable, and sustainable cybersecurity practices.

Conclusion

The proposed security architecture marks a critical transformation in the bank's defensive posture, moving from a flat, reactive environment to a segmented, monitored, and policy-driven infrastructure. By addressing the root causes of the breach—such as lack of segmentation, insufficient endpoint controls, and poor visibility—the bank's new design minimizes lateral movement, hardens device and user access, and introduces real-time monitoring across all critical systems.

With a strategic investment of $400,000, the bank has prioritized the most impactful and cost-effective technologies: network segmentation, endpoint protection, centralized SIEM, identity management, encrypted backups, secure remote access, and employee training. Each solution directly maps to regulatory mandates under GLBA, FFIEC, and PCI DSS, ensuring both legal compliance and technical resilience.

Importantly, the architecture is designed for sustainability. It can be maintained by a single full-time security administrator and adjusted flexibly within the available budget. The integration of measurable performance metrics—such as MTTD/MTTR, phishing resilience, and backup recovery time—ensures that security improvements can be monitored and validated over time.

Beyond technology,this plan reflects a cultural shift toward cybersecurity awareness, accountability, and continuous improvement. It reaffirms the bank's commitment to customer trust, operational continuity, and proactive risk management in an increasingly hostile cyber landscape.